

Documentation : Audit de sécurité Active Directory (WIN-SERV) avec PingCastle.

1. Présentation de l'outil

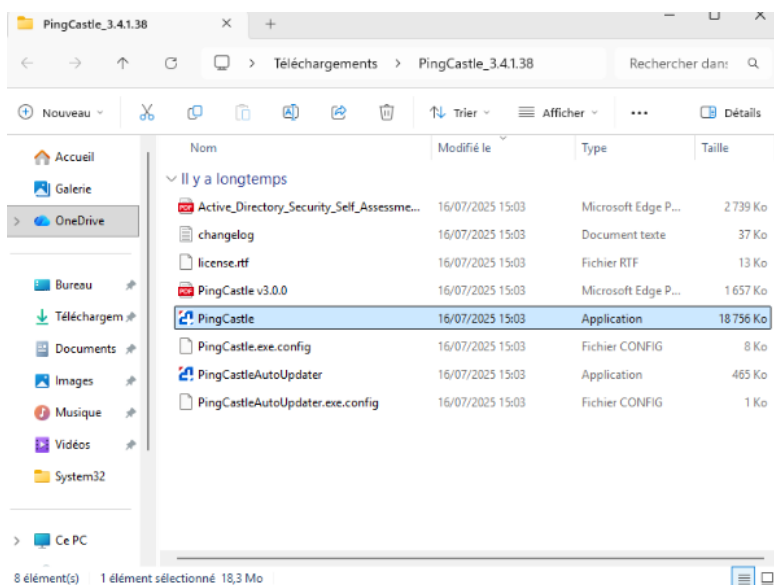
PingCastle est un outil de référence pour auditer la sécurité d'un domaine Active Directory (AD). Il évalue le niveau de risque global et détaille les vulnérabilités par catégories afin de proposer un plan d'action correctif.

2. Préparation et Lancement

L'outil se présente sous la forme d'une archive contenant un exécutable Windows. Il doit être lancé depuis un poste joint au domaine (ex: Windows 11) avec des privilèges d'administration pour un scan complet.

Procédure de lancement :

1. **Extraction** : Décompressez l'archive PingCastle_3.4.1.38.zip.
2. **Exécution** : Lancez le programme via le fichier PingCastle.exe.



3. Configuration du Scan (Interactif)

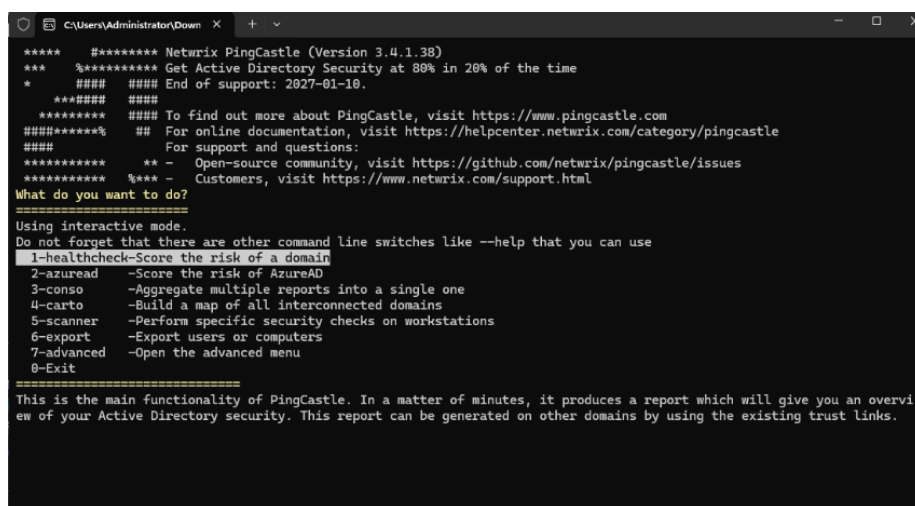
Une fois lancé, l'outil propose un menu interactif dans une console. Voici les étapes à

suivre selon vos captures :

Étape 1 : Choix de la fonctionnalité

Sélectionnez l'option principale pour évaluer le risque du domaine.

- **Action** : Tapez 1
- **Commande** : 1-healthcheck-Score the risk of a domain

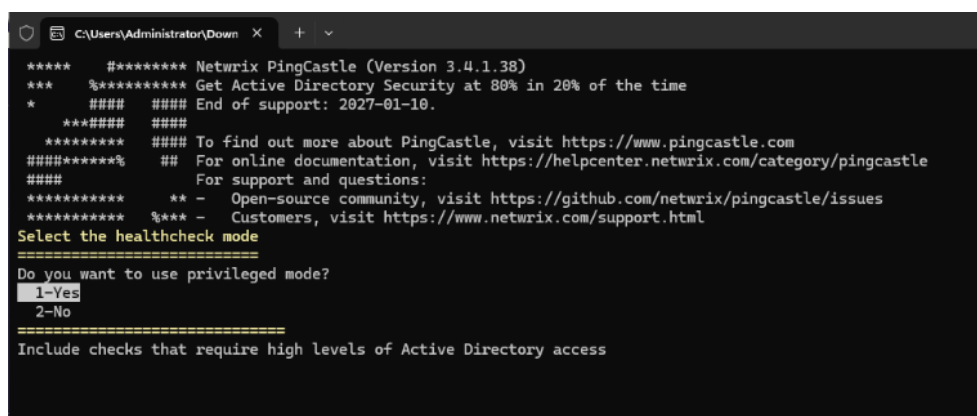


```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.
```

Étape 2 : Mode de privilèges

Pour obtenir tous les détails techniques, activez le mode privilégié.

- **Action** : Tapez 1
- **Commande** : 1-Yes (Include checks that require high levels of Active Directory access)



```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select the healthcheck mode
=====
Do you want to use privileged mode?
1-Yes
2-No
=====
Include checks that require high levels of Active Directory access
```

Étape 3 : Sélection du domaine

Spécifiez le domaine à analyser. Par défaut, l'outil détecte celui de votre session.

- **Action** : Appuyez sur **Entrée** pour valider le domaine par défaut.

- Cible : stage.local

```

C:\Users\Administrator\Down X + v

***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select a domain or server
=====
Please specify the domain or server to investigate (default:lab.local)

```

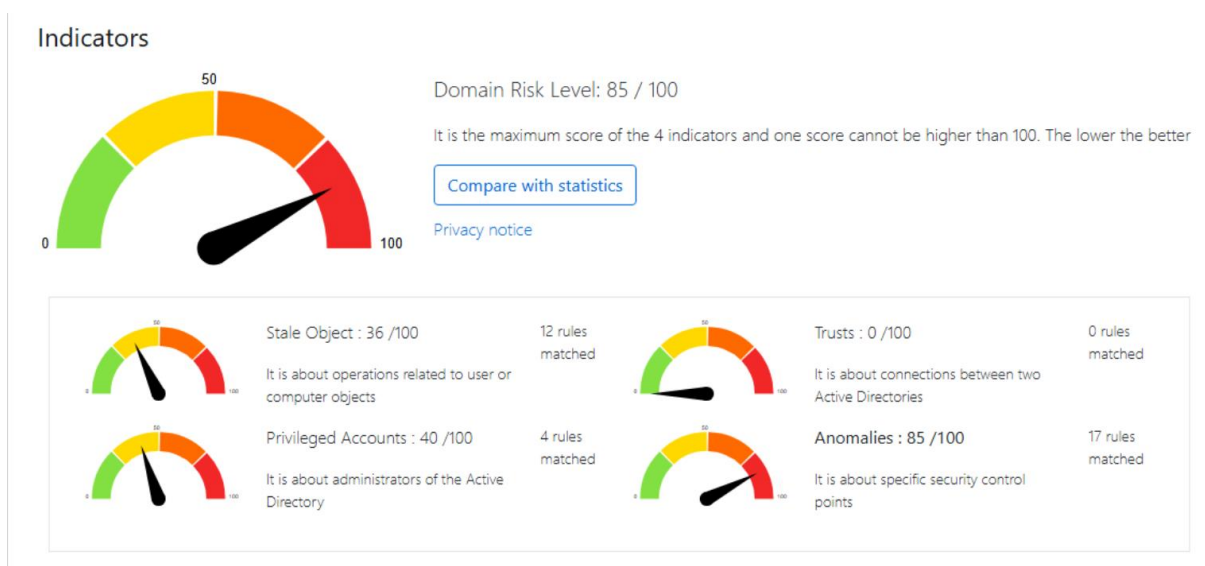
```

C:\Users\Administrator\Down X + v

***** #***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select a domain or server
=====
Please specify the domain or server to investigate (default:lab.local)

Free Edition of PingCastle - Not for commercial use
Starting the task: Perform analysis for lab.local
[09:15:33] Getting domain information (lab.local)
Performance warning: using LDAP instead of ADWS
[09:15:39] Gathering general data
[09:15:41] Gathering user data
[09:15:41] Gathering computer data
[09:15:41] Gathering trust data
[09:15:41] Gathering privileged group and permissions data
[09:15:41] - Initialize
[09:15:41] - Searching for critical and infrastructure objects
[09:15:41] - Collecting objects - Iteration 1

```



Domain Risk Level : 85 / 100. Le domaine se situe profondément dans la **zone rouge**, ce

qui indique un niveau de risque critique. Une intervention immédiate est nécessaire pour sécuriser l'annuaire, car ce score reflète la vulnérabilité la plus élevée parmi les indicateurs surveillés.

1. Analyse des Anomalies (Score : 85 / 100)

Explication (Cause) : L'audit identifie un niveau critique d'anomalies techniques avec **17 règles** de sécurité enfreintes. Ce score signale la présence de configurations techniques dangereuses, l'utilisation de protocoles obsolètes ou des écarts de sécurité majeurs spécifiques à l'environnement analysé.

Conséquence (Risque) : Un score d'anomalies aussi élevé représente la vulnérabilité la plus immédiate de l'infrastructure. Ces failles constituent des points d'entrée privilégiés pour des attaquants et nécessitent une priorité absolue en matière de remédiation pour abaisser le niveau de risque global du domaine.

2. Sécurité des comptes privilégiés (Privileged Accounts - 40 / 100)

Explication (Cause) : L'analyse détecte **4 règles** critiques concernant la gestion des comptes administrateurs. Cet indicateur révèle une surface d'attaque significative sur les accès à hauts privilèges au sein du domaine `lab.local`.

Conséquence (Risque) : Un score élevé dans cette catégorie est souvent lié à une gestion des droits trop permissive ou à une protection insuffisante des comptes sensibles. Cela facilite l'escalade de privilèges et la prise de contrôle de l'annuaire par un acteur malveillant.

3. Gestion des objets obsolètes (Stale Objects - 36 / 100)

Explication (Cause) : L'audit relève **12 règles** liées à l'hygiène de l'Active Directory, signalant un manque de nettoyage des ressources inactives. Cela concerne notamment des comptes utilisateurs ou des comptes machines qui n'ont enregistré aucune activité depuis une période prolongée.

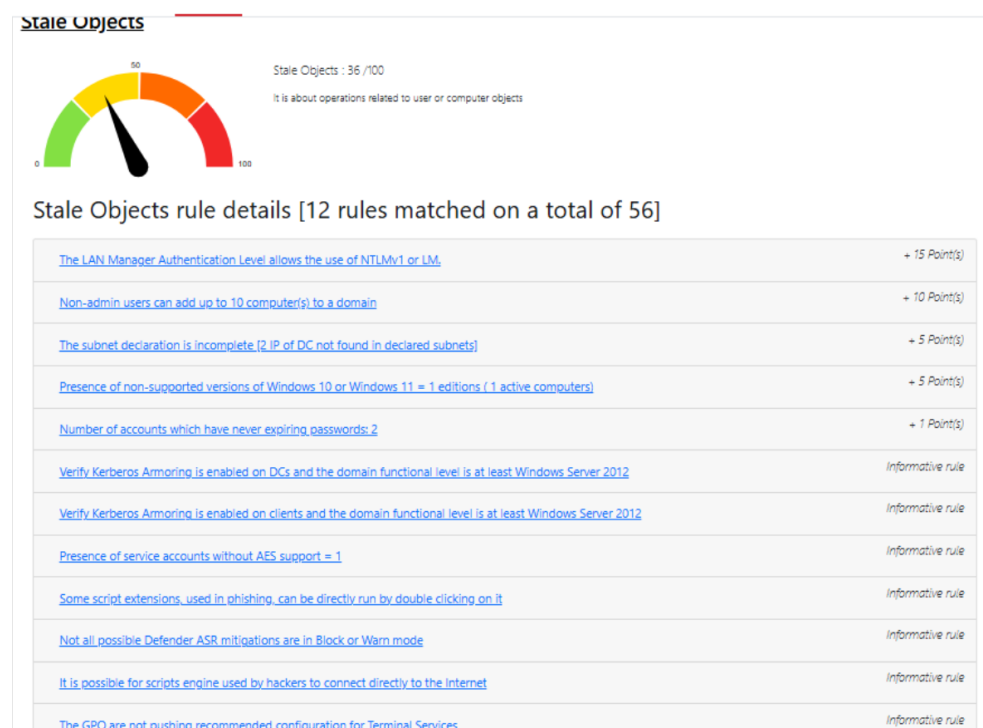
Conséquence (Risque) : La pollution de l'annuaire par des objets obsolètes offre des vecteurs de persistance discrets. Un attaquant peut utiliser ces comptes inactifs pour maintenir un accès au réseau sans attirer l'attention des systèmes de surveillance, facilitant ainsi les phases de reconnaissance et de mouvement latéral.

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Azure	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

Legend:

- score is 0 - no risk identified
- score is 0 - no risk identified but some improvements detected
- score between 1 and 10 - a few actions have been identified
- score between 10 and 30 - rules should be looked with attention
- score higher than 30 - major risks identified

Le code couleur de PingCastle est simple : **Orange** signifie que les règles doivent être examinées avec attention (score entre 10 et 30), et **Jaune** indique quelques actions identifiées.



Analyse détaillée des règles "Stale Objects" (Hygiène de l'AD)

PingCastle a identifié **12 règles** correspondantes dans cette catégorie :

- **NTLMv1 ou LM autorisé (+15 points)** : Le niveau d'authentification LAN Manager autorise encore l'usage de protocoles obsolètes et vulnérables. C'est une faille

critique car ces protocoles sont facilement interceptables et cassables, facilitant les attaques par relais ou par force brute.

- **Ajout de machines par des non-admins (+10 points)** : Par défaut, les utilisateurs non-administrateurs peuvent joindre jusqu'à 10 ordinateurs au domaine. Cela permet potentiellement à un utilisateur malveillant d'introduire des machines non maîtrisées ou compromises au sein de l'infrastructure.
- **Déclaration de sous-réseau incomplète (+5 points)** : Deux adresses IP de contrôleurs de domaine (DC) n'ont pas été trouvées dans les sous-réseaux déclarés. Cela peut entraîner des problèmes de localisation des services et une latence réseau lors de l'authentification des clients.
- **Versions non supportées de Windows (+5 points)** : La présence d'une machine active tournant sous une édition non supportée de Windows 10 ou 11 est détectée. Ces systèmes ne reçoivent plus de mises à jour de sécurité, représentant une porte d'entrée facile pour les vulnérabilités récentes.
- **Comptes avec mots de passe n'expirant jamais (+1 point)** : Deux comptes possèdent des mots de passe sans date d'expiration. Cela augmente le risque de persistance si un compte est compromis, car le mot de passe n'est jamais renouvelé.
- **Extensions de scripts dangereuses (Information)** : Certaines extensions utilisées dans le phishing peuvent être exécutées par un simple double-clic. Cela souligne un manque de durcissement (hardening) des politiques de sécurité sur les postes de travail.
- **Configuration des services de terminaux (Information)** : Les GPO ne poussent pas les configurations recommandées pour les services de bureau à distance (Terminal Services), ce qui peut laisser des vecteurs d'attaque ouverts sur les accès RDP.
- **Sécurité des scripts et accès Internet (Information)** : Le moteur de script peut être utilisé par des attaquants pour se connecter directement à Internet. De plus, les règles de réduction de la surface d'attaque (Defender ASR) ne sont pas toutes configurées en mode "Blocage" ou "Avertissement".

Privileged Accounts



Privileged Accounts rule details [4 rules matched on a total of 46]

Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 1	+ 20 Point(s)
The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
OU without the accidental deletion protection have been found	Informative rule

Analyse détaillée des règles "Privileged Accounts"

PingCastle a identifié **4 règles** correspondantes dans cette catégorie :

- **Absence du flag "Sensitive and cannot be delegated" (+20 points)** : Un compte administrateur ne possède pas l'attribut de sécurité empêchant sa délégation. C'est une vulnérabilité critique qui peut permettre à un attaquant de voler les jetons d'accès de cet administrateur pour s'introduire plus profondément dans le réseau via des attaques de type "Kerberoasting" ou "Delegation".
- **Le groupe Schema Admins n'est pas vide (+10 points)** : Un compte est présent dans le groupe des administrateurs du schéma. Ce groupe ne devrait contenir des membres que de façon temporaire lors de modifications de la structure de l'annuaire, car ses membres possèdent des droits de modification irréversibles sur la base Active Directory.
- **La corbeille AD n'est pas activée (+10 points)** : La fonctionnalité de "Recycle Bin" n'est pas activée pour l'Active Directory. En cas de suppression accidentelle ou malveillante d'un objet critique (comme une Unité d'Organisation ou un compte admin), la restauration sera complexe et risquée, impactant la disponibilité du domaine.
- **Unités d'Organisation (OU) sans protection contre la suppression accidentelle (Information)** : Des OU ont été trouvées sans la coche de protection contre la suppression. Cela expose l'annuaire à des erreurs de manipulation humaine qui pourraient déstructurer l'arborescence et les politiques de sécurité appliquées.

Anomalies analysis



Anomalies rule details [17 rules matched on a total of 73]

LAPS doesn't seem to be installed	+ 15 Point(s)
Last AD backup has been performed 13 day(s) ago	+ 15 Point(s)
The spooler service is remotely accessible from 1 DC	+ 10 Point(s)
Policy where the password length is less than 8 characters: 1	+ 10 Point(s)
RPC interfaces of DC are likely vulnerable to coercion attacks. Identified interfaces: 4	+ 10 Point(s)
The audit policy on domain controllers does not collect key events.	+ 10 Point(s)
The number of DCs is too small to provide redundancy: 1 DC	+ 5 Point(s)
A LDAP authentication without signature enforcement was allowed	+ 5 Point(s)
Hardened Paths have been modified to lower the security level	+ 5 Point(s)
No password policy for service accounts found (MinimumPasswordLength>=20)	Informative rule
No GPO has been found which disables LLMNR or at least one GPO does enable it explicitly	Informative rule

Analyse détaillée des règles "Anomalies"

PingCastle a identifié **17 règles** correspondantes dans cette catégorie :

- **Absence de LAPS (+15 points)** : La solution LAPS (Local Administrator Password Solution) ne semble pas installée. Sans cet outil, les mots de passe des administrateurs locaux sont souvent identiques sur tous les postes, facilitant les déplacements latéraux d'un attaquant après le compromis d'une seule machine.
- **Délai de sauvegarde excessif (+15 points)** : La dernière sauvegarde de l'Active Directory remonte à **13 jours**. En cas de cyberattaque (type ransomware) ou de panne majeure, je risque une perte de données importante et une incapacité à restaurer l'annuaire dans un état récent.
- **Service Spooler accessible à distance (+10 points)** : Le service d'impression est activé et accessible à distance sur un contrôleur de domaine. C'est une vulnérabilité majeure (type PrintNightmare) qui peut permettre à un attaquant de prendre le contrôle total du DC.
- **Politique de mots de passe trop faible (+10 points)** : Au moins une politique autorise des mots de passe de **moins de 8 caractères**. Cette faiblesse expose le domaine à des attaques par dictionnaire ou par force brute extrêmement rapides.
- **Vulnérabilité aux attaques de coercition RPC (+10 points)** : Les interfaces RPC des contrôleurs de domaine sont vulnérables (4 interfaces identifiées). Cela permet à un attaquant de forcer le DC à s'authentifier contre une machine malveillante pour voler ses identifiants (attaques type PetitPotam).
- **Audit de sécurité incomplet (+10 points)** : La politique d'audit sur les contrôleurs de domaine ne collecte pas les événements clés. En cas d'intrusion, il sera impossible de retracer les actions de l'attaquant ou de détecter les anomalies de connexion.
- **Défaut de redondance des DC (+5 points)** : Le domaine ne dispose que d'**un seul contrôleur de domaine**. S'il tombe en panne, l'intégralité du réseau et des services d'authentification s'arrête immédiatement.
- **Authentification LDAP non signée (+5 points)** : L'authentification LDAP sans signature forcée est autorisée. Cela expose les identifiants circulant sur le réseau à des interceptions ou des attaques de type "Man-in-the-Middle".
- **Protocoles de résolution de noms dangereux (Information)** : Aucun GPO ne désactive **LLMNR**. Ce protocole obsolète est utilisé par les attaquants pour capturer des condensés (hashes) de mots de passe sur le réseau local via des outils comme Responder.
- **Configurations DNS et PowerShell permissives (Information)** : Les utilisateurs authentifiés peuvent créer des enregistrements DNS, et l'audit PowerShell n'est pas totalement activé. Cela facilite la création de faux services et limite la visibilité sur l'exécution de scripts malveillants.

Synthèse des Recommandations

Pour abaisser le score de risque global sous la barre des **30 (zone Verte)**, les actions suivantes sont prioritaires :

- **Sécuriser les configurations techniques (Anomalies)** : Déployer la solution **LAPS** (Local Administrator Password Solution) pour individualiser les mots de passe locaux

et augmenter immédiatement la fréquence des sauvegardes de l'Active Directory (actuellement à 13 jours).

- **Neutraliser les failles de coercition et d'accès** : Désactiver le service **Spooler d'impression** sur votre contrôleur de domaine et restreindre les interfaces RPC vulnérables pour bloquer les attaques de type PetitPotam.
- **Renforcer la surveillance et la disponibilité** : Activer les politiques d'audit avancées pour tracer les événements critiques et envisager l'ajout d'un **second contrôleur de domaine** pour éliminer le point de défaillance unique actuel.
- **Protéger les comptes à hauts privilèges** : Cocher l'option "**Account is sensitive and cannot be delegated**" pour vos administrateurs et videz le groupe "**Schema Admins**", qui ne doit être utilisé que ponctuellement.
- **Améliorer l'hygiène globale (Stale Objects)** : Désactiver le support des protocoles **NTLMv1/LM** et ramener à **0** le nombre de machines qu'un utilisateur non-admin peut joindre au domaine (quota MS-DS-Machine-Account-Quota).
- **Activer les protections natives** : Activer la **Corbeille Active Directory** (Recycle Bin) pour sécuriser la restauration d'objets et protéger les Unités d'Organisation contre la suppression accidentelle.
- **Nettoyer les protocoles réseau** : Désactiver par GPO les protocoles de résolution de noms obsolètes comme **LLMNR** et imposer la signature LDAP pour prévenir les interceptions de trafic.